

Directives du personnel

Sécurité des informations



Conception du Système de Résilience et Alignement sur les Normes

Ce système de résilience a été conçu par Risk and Strategic Management, Corp (RSM), une société spécialisée dans la conception et la mise en œuvre de stratégies de résilience complexes qui protègent les personnes, les installations, les actifs, les informations, les opérations et la réputation de l'organisation. Ce système a été aligné sur les normes ISO et BSI suivantes afin de garantir qu'il reflète les normes et pratiques professionnelles des organisations à haute fiabilité : ISO 31000 : Gestion du risque ; ISO 22317 : Analyse de l'impact sur l'entreprise ; ISO 22301 : Gestion de la continuité de l'activité ; ISO 22320 : Gestion des urgences ; ISO 34001 : Sécurité et résilience ; ISO 22316 : Résilience organisationnelle ; et BSI 17091 : Gestion de crise.

Pourquoi la sécurité de l'information est-elle importante

Une sécurité efficace des informations garantit qu'aucune donnée n'est perdue, volée ou laissée sans sécurité, quelle que soit la sensibilité des données. Toute information pouvant causer du tort ou de l'embarras à des individus, à l'organisation ou à des parties prenantes externes par des criminels, des gouvernements hostiles, médias, militants ou des terroristes doit être considérée comme sensible et doit être protégée de manière appropriée.

Voici des exemples spécifiques d'informations sensibles :

- Informations contractuelles et financières
- Plans et rapports opérationnels
- Stratégies organisationnelles
- Informations sur les parties prenantes externes
- Propositions commerciales
- Visites et activités VIP
- Propriété intellectuelle
- Dossiers et horaires de voyage
- Données biographiques du personnel et enregistrements du plus proche parent
- Rapports promotionnels et disciplinaires
- Politiques ou rapports de crise et d'incident
- Documents d'assurance
- Forfaits de rémunération
- Rendez-vous clients et événements
- Enquêtes
- Politiques et plans de sécurité

Les risques d'une mauvaise sécurité de l'information comprennent :

- Vols, cambriolages, agressions et cambriolages
- Agressions entraînant des blessures ou la mort
- Enlèvement et prise d'otages
- Attaques armées
- Attention médiatique négative
- Perte d'avantage concurrentiel et d'affaires
- Gêne d'un individu ou d'une organisation
- Risques juridiques et de réputation
- Dommages au moral des employés
- Préjudice aux parties prenantes externes

Vos responsabilités...

Des pratiques fiables de sécurité des informations peuvent réduire considérablement le risque que notre organisation soit ciblée par des individus et des groupes hostiles, protégeant ainsi les personnes, les informations, les opérations et nos intérêts commerciaux. Le non-respect de ces mesures entraînera inévitablement une atteinte à la sécurité. La sécurité de l'information comprend :

- Limiter l'accès à vos données, en utilisant des couches de protocoles de cryptage et de sécurité
- La sécurisation des actifs de stockage de données physiques ou des informations sur papier
- Réduire les vulnérabilités qui pourraient permettre la perte de données ou le vol
- Le signalement immédiat des failles de sécurité
- Être conscient de votre environnement et des endroits où les autres peuvent entendre vos conversations

Protocoles de sécurité des données

Voici quelques-uns des domaines dans lesquels vous êtes responsable de la sécurité de l'information :

- 1. Politique de bureau transparent :** les informations sensibles doivent être mises sous clé lorsqu'elles ne sont pas utilisées, en particulier pendant la nuit lorsque les nettoyeurs peuvent avoir un accès illimité à l'installation. Le personnel utilisant des données sensibles doit disposer d'armoires ou de pièces verrouillables où les données peuvent être sécurisées.
- 2. Voyager avec des données :** les voyageurs doivent déterminer les informations dont ils ont besoin pour le voyage et si la perte d'informations peut compromettre les individus, l'organisation ou d'autres parties prenantes. Si le risque de perte ou de vol est élevé, les individus peuvent avoir besoin de demander un ordinateur portable aseptisé. Seules les informations essentielles doivent être transportées, généralement sur un lecteur flash crypté ou un disque dur externe.
- 3. Vol de données :** si des personnes perdent des données ou se font voler des actifs, elles doivent immédiatement signaler l'incident à un responsable et fournir une liste complète des informations volées afin qu'une évaluation des risques puisse être menée sur les implications potentielles de la perte. Toutes les parties concernées, y compris les parties prenantes externes, les destinataires des bureaux, les partenaires, les exécutants et les sous-traitants, peuvent avoir besoin d'être notifiées par un responsable approprié. La police et / ou les agences gouvernementales pourraient également avoir besoin d'être informées. Les mêmes considérations s'appliquent si l'on pense que les données ont été compromises.

4. **Effacement des données** : le service des technologies de l'information est responsable de l'élimination lors de l'élimination des ordinateurs, des disques durs, des lecteurs flash et des équipements réseau.
5. **Élimination des données matérielles** : les fichiers de données matérielles, le papier et les documents doivent être détruits d'une manière qui protège l'intégrité de l'information. Ceci peut être réalisé grâce à une déchiqueteuse, ou, en l'absence d'une déchiqueteuse, les documents peuvent être brûlés.
6. **Mots de passe**: créez des mots de passe longs (au moins 8 caractères) avec des chiffres, des caractères à casse mixte et des symboles spéciaux. Un bon exemple de mot de passe serait : *Il0veMyMutæR5934*. Un mauvais exemple serait : *JohnDoe*. **N'UTILISEZ PAS** de mots de passe pouvant être liés à qui vous êtes, tels que des mots de passe comprenant votre numéro de sécurité sociale (SSN), votre date de naissance, les noms de vos enfants ou le deuxième prénom de votre conjoint. Au lieu de cela, créez un mot de passe aléatoire avec des chiffres, des lettres, des symboles (si autorisé) et des lettres majuscules et non majuscules. Essayez de créer un mot de passe dont vous vous souviendrez sans avoir à l'écrire, mais qui reste aussi aléatoire que possible. Si vous devez noter un mot de passe, conservez-le dans un endroit sûr tel que votre portefeuille. **NE CONSERVEZ PAS** votre mot de passe avec votre ordinateur.
7. **Virus / logiciels espions / cookies** : lorsque vous accédez à Internet, en particulier si vous téléchargez à partir d'un serveur ouvert, vous accumulerez des logiciels espions et des cookies. Ceux-ci peuvent être supprimés à l'aide d'un outil de suppression des cookies / spyware. Les virus, vers et chevaux de Troie sont plus difficiles à supprimer. Ils peuvent généralement être évités :
- **NE PAS OUVRIR** de pièces jointes ou de liens dans un e-mail à moins que vous ne puissiez vérifier de qui il provient.
 - **NE PAS DÉACTIVER** votre pare-feu. Réglez le niveau de sécurité à son niveau le plus élevé.
 - **NE PAS DÉACTIVER** votre protection contre les pop-ups.
 - **NE PAS TÉLÉCHARGER** de torrents, de fichiers venant d'emplacements peer-to-peer. Communiquez avec le service des technologies de l'information si vous soupçonnez qu'un site est frauduleux.
 - **NE PAS LAISSER TRAÎNER** de mots de passe, votre ordinateur déverrouillé ou sans surveillance dans un espace public.
 - **NE PAS DONNER** d'informations personnelles ou organisationnelles à quelqu'un que vous ne connaissez pas et en qui vous n'avez pas confiance. Si possible, vérifiez leur identité auprès d'un tiers de confiance avant de communiquer avec des personnes inconnues.

Vol de données : faites particulièrement attention à votre ordinateur lorsque vous vous rendez dans des zones publiques et / ou dangereuses. Dangereux peut être défini comme tout endroit où vos disques durs ou matériel sensible risque d'être volé, cassé ou altéré.

- Gardez toujours votre ordinateur dans un endroit sûr. Si possible, verrouillez votre ordinateur pour empêcher le vol. Si vous séjournez dans une chambre d'hôtel avec un coffre-fort, utilisez-le pour ranger votre ordinateur et tous les documents sensibles si vous laissez la chambre inoccupée.
- Stockez tous les fichiers de l'ordinateur dans un dossier système partagé pour vous assurer qu'il est sauvegardé chaque fois que vous vous connectez à l'Internet.
- Si vous devez laisser un ordinateur portable dans un véhicule, fixez-le dans le camion / coffre, et non sur les sièges du véhicule, ce qui pourrait attirer l'attention des criminels.

Protocoles de gestion de la sécurité individuelle

La protection des informations peut concerner ce que vous dites et faites lorsque vous voyagez, socialisez ou travaillez. Être conscient de la situation de votre environnement et de ce que vous et les autres dites et faites est très important. Certaines règles de sécurité des informations importantes incluent :

- **Photos et vidéos :** ne prenez pas et ne transmettez pas de photographies ou de vidéos de zones, de personnes ou d'activités sensibles, à moins que vous n'ayez été autorisé à le faire. Cela peut fournir des informations compromettantes qui peuvent être utilisées pour présenter une menace pour les personnes, les biens et les opérations. Cela peut également causer une gêne importante, surtout s'il est partagé avec les médias. Si vous êtes autorisé à prendre des photos et des vidéos, vous ne devez pas les partager tant qu'une activité n'est pas terminée.
- **E-mails et SMS :** supposez que les e-mails et SMS transmis à l'extérieur de l'organisation ne sont pas sécurisés. Ceux-ci peuvent être facilement interceptés par des groupes hostiles ou peuvent être partagés avec un groupe beaucoup plus large que l'expéditeur n'avait pas prévu.
- **Médias sociaux :** vous ne devez pas publier d'images, d'informations ou de commentaires liés à l'organisation sur toute forme de médias sociaux sans approbation – ce sont des supports ouverts pour le partage d'informations publiques et seront rapidement partagés avec un groupe beaucoup plus large que vous ne le souhaiteriez. Ne publiez jamais d'informations sensibles sur une activité avant qu'elle ne se produise – cela donnera aux individus et aux groupes hostiles le temps de planifier et de mettre en œuvre leurs objectifs, car vous leur avez fourni les informations nécessaires

pour y parvenir. Vous devez supposer que tout le monde peut accéder à vos informations sur les réseaux sociaux.

- **Conversations et appels téléphoniques** : vous devez toujours être conscient de votre environnement et supposer que d'autres peuvent écouter vos conversations ou vos appels téléphoniques. Souvent, les gens oublient qu'ils peuvent se trouver à proximité et jusqu'où le son se déplace, ce qui vous amène, à vous ou à d'autres, à divulguer sans le savoir des informations sensibles. Vous devriez trouver un endroit isolé ou privé pour tenir des discussions ou des appels téléphoniques. Vous devez également comprendre que certaines zones peuvent être piégées par des dispositifs électroniques d'écoute, comme les salles de conférence et les chambres d'hôtel.
- **Partager avec vos amis et votre famille** : vous devez comprendre que même si vous pouvez faire confiance à votre famille et à vos amis, les gens ont tendance à bavarder et il existe un réel danger qu'ils parlent de vos activités à quelqu'un sans intention de nuire à vous. Ils peuvent également envoyer des e-mails, partager des photos ou des documents, ou être eux-mêmes entendus, vous compromettant ainsi que d'autres. En tant que tel, vous devez être sélectif avec ce que vous partagez et les mettre en garde contre les mesures de sécurité des informations.
- **Lecture de rapports et de documents** : Souvent, les gens veulent lire des documents ou des rapports sur leur ordinateur portable ou des copies papier lorsqu'ils voyagent. Souvent, ils ne savent pas que d'autres peuvent être en mesure de lire les informations, en particulier dans les vols ou dans les trains où des personnes se trouvent à proximité. Il faut veiller à ce que les gens ne puissent pas lire les informations « par-dessus votre épaule ». Des écrans de protection peuvent être utilisés sur les ordinateurs portables pour réduire ce risque.

Autres instructions